

bcrypt por dentro

Um hash de senhas que é lento de propósito. · Provos & Mazières, USENIX 1999

Isabela Sousa & Paulo Victor Almeida · 8 blocos visuais

1 O problema: guardar senhas

Se o banco vazar, o que o atacante consegue? Depende de como a senha foi guardada.

Texto puro
Vazou = todas as senhas expostas.

SHA-256 / MD5
Rápidos demais: bilhões de palpites por segundo em GPU.

bcrypt
Lento e ajustável: cada palpite custa milhares de cifragens.

2 Os três ingredientes

Tudo o que o bcrypt recebe e por que cada parte existe.

senha
até 72 bytes (UTF-8 + \0)

sal
16 bytes aleatórios, únicos por senha

custo
 2^{custo} iterações (4 a 31)

3 Anatomia do hash (60 caracteres)

`$2b$12$R9h/cIPz0gi.URNNX3kh20PST9/PgBkqquzi.Ss7KIUg02t0jWMUW`

\$2b\$
versão

12
custo → 4096 iterações

22 chars
sal (16 bytes)

31 chars
hash (23 bytes)

4 A base: cifra Blowfish

Rede de Feistel com 16 rodadas, bloco de 64 bits e tabelas iniciais tiradas dos dígitos de π ($P[0] = 243F6A88$).

Vetor P
18 subchaves de 32 bits

+

4 caixas S
256 palavras cada (4 KB)

→

F(x)
 $((S0[a]+S1[b]) \oplus S2[c]) + S3[d]$

5 O algoritmo em 6 passos

1 · Chave
senha + \0, máx. 72 bytes

2 · Estado
 P e $S \leftarrow$ dígitos de π

3 · ExpandKey
(sal, senha)

4 · Repetir 2^{custo} x
 $\text{ExpandKey}(\text{senha})$ e $\text{ExpandKey}(\text{sal})$

5 · Cifrar 64x
“OrpheanBeholderScryDoubt”

6 · Montar hash
 $\$2b\$ + \text{custo} + \text{base64}(\text{sal}) + \text{base64}(\text{saída})$

6 Custo: cada +1 dobra o esforço

Medido na nossa implementação, em cifragens Blowfish por hash.

Custo	Iterações	Cifragens	Razão
4	16	17.385	—
5	32	34.057	×1,96
6	64	67.401	×1,98
7	128	134.089	×1,99
12	4096	≈ 4,3 milhões	recomendado hoje

7 Verificar senha no login

1 · Ler
versão, custo e sal do hash guardado

→

2 · Recalcular
 $\text{bcrypt}(\text{senha digitada}, \text{mesmo custo e sal})$

→

3 · Comparar
23 bytes em tempo constante

8 Limitações e alternativas

72 bytes
O excedente é ignorado — use pré-hash.

Pouca memória
~4 KB: GPUs ainda ajudam o atacante.

Argon2id / scrypt
Memory-hard; recomendados em sistemas novos.